Data privacy & security

UdyamOne | Current V3 design | Reviewed 7 November 2026

> UdyamOne uses purpose-specific consent, limited document retention and controlled order access. This note distinguishes implemented prototype protections from requirements that must be completed before production deployment.

1. Purpose and consent

Business needs and reviewed services support planning; contact details support accepted orders; lane-specific documents support verification. Order creation requires consent. Bill OCR, KYC and registry lookup have separate consent checks, and revised plans require fresh acceptance. Assistance assignment does not initiate outreach; real contact and pilot participation require appropriate consent.

2. Data minimisation

Uploads have 8 MB limits and image checks. Temporary image files are removed after processing; raw OCR is not persisted by the API. Reviewed bill fields may enter accepted plans. KYC retains status/verdict and logs notice version, time, purpose, lane, order reference and finding codes. Order-linked records are pseudonymous and remain subject to data protection controls.

3. Access and application security

Local demo orders receive random access tokens stored as SHA-256 hashes. The pilot foundation adds phone-OTP customer sessions and OIDC staff tokens with role claims; the shared ADMIN_TOKEN is not accepted as a production identity design. Customer responses omit operator evidence. Input validation, parameterized SQL, request limits, escaped dynamic output, security headers and order-bound KYC reduce unauthorized access and injection risks.

4. Transaction and integration integrity

The server recomputes quotes and validates plan fingerprints before acceptance. Activation updates use version checks and duplicate-event protection. Provider callbacks have signature and payload-size checks; payment updates must match the order reference, amount and currency. Provider errors do not establish successful verification, payment or activation.

5. External processing

Cashfree receives the registration fields needed for a consented lookup; only scoped results are retained. Razorpay checkout is TEST-only; card data is not stored by UdyamOne. Meta processes WhatsApp numbers and messages. V3 explanations are deterministic; optional Anthropic legacy explanations receive quote facts. Optional speech services receive generated prompts or browser microphone input. UdyamOne's speech cache is memory-only; provider-side retention requires contractual review. Credentials remain on the server.

6. Retention, rights and production readiness

WhatsApp stores phone/session state while requesting consent; business answers follow YES. STOP clears the session, and inactive sessions are removed on a later inbound request after 24 hours. Receipts persist for deduplication. Pilot consent events are stored in PostgreSQL; other records still need an approved automated retention schedule. Production deployment additionally requires gateway TLS, managed encryption keys, distributed limits, secret rotation, immutable audit export, incident handling and tested backup restoration. Define correction, withdrawal and deletion across records, backups and providers; appoint accountable contacts and validate processor contracts and notices. This design is not a compliance certification.